

VPC anatomy

Day 3 - Morning

Running scenario: Thara Hospitals patient portal pilot

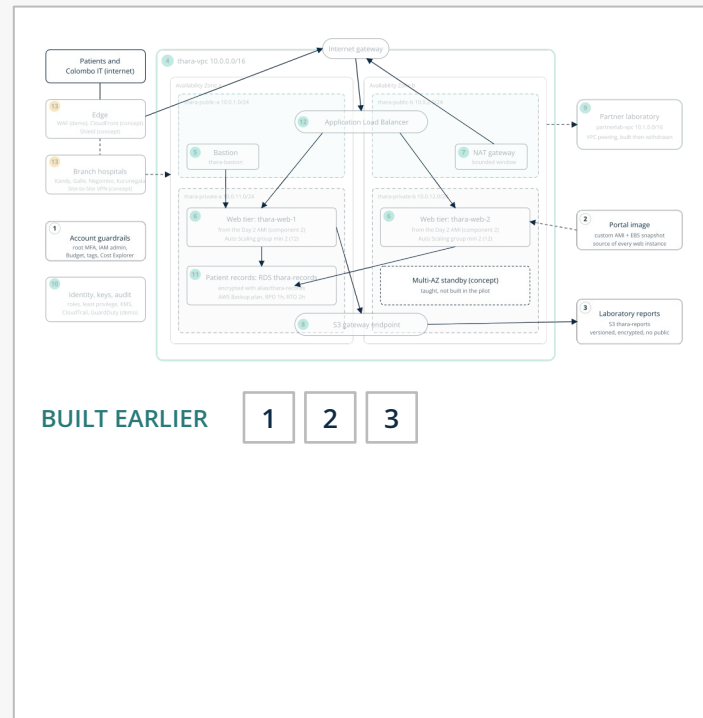
Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management



Today

The portal has a server and an image. Today it gets a network of its own.

- A VPC is a network you already know - 30 min
- Two firewalls, two behaviours - 35 min
- Seeing the traffic - 20 min



CONCEPT 1

A VPC is a network you already know

thara-vpc is the Colombo basement rebuilt, with two buildings.

30 min

A network made of software

- A VPC is a private network in one region, with a CIDR block: `thara-vpc`, 10.0.0.0/16
- A subnet is a slice of that range, bound to **one** availability zone
- Two zones, two subnets for each tier, so one flood cannot take both

YOU ALREADY KNOW THIS

VLANs, an L3 switch's routing table, and the edge router's default route.

T**THARA HOSPITALS**

The Colombo basement rebuilt, with two buildings in place of one.

Route tables decide where packets go



- A route table is a list: for this destination range, use that target
- Every table carries the VPC's own range to **local**, which cannot be removed
- A subnet is associated with **exactly one** route table
- Not associated? It silently uses the **main route table**

Associations are where a hand build most often goes wrong.

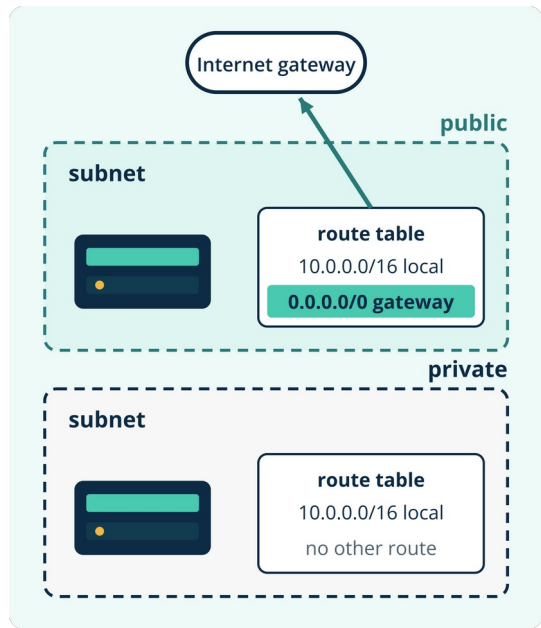
What makes a subnet public

- The internet gateway is the VPC's door, attached once
- Public means a default route to the gateway **and** a public address
- The name of the subnet plays no part

COMMON MISTAKE

A subnet named public is public.

Only a route to the gateway, plus a public address, makes it so.



Same drawing, one route apart.

Public addresses, and the default VPC

- An auto-assigned public address is borrowed: stop the instance and it is gone
- An **Elastic IP** stays yours until you release it, and can be moved
- Every public IPv4 address costs USD 0.005 an hour, in use or idle
- The default VPC makes every subnet public: fine for a first server, wrong for real work

From today everything goes into `thara-vpc`.

CONCEPT 2

Two firewalls, two behaviours

The bastion only from the IT office. The database only from the web tier.

35 min



IT

HEAD OF IT

My team gets in from the Colombo IT office, through one door. Nothing behind that door is reachable from the internet. Show me the rules that make that true.

The Head of IT, on private administrative access.

Two firewalls, two behaviours

Security group

- On a network interface, so in effect an instance
- **Stateful**: replies pass automatically
- Allow rules only
- Evaluated as a whole: any allow passes

Network ACL

- On a subnet
- **Stateless**: every packet judged alone
- Allow and deny rules
- Numbered order: the first match decides

The reply is where they differ.

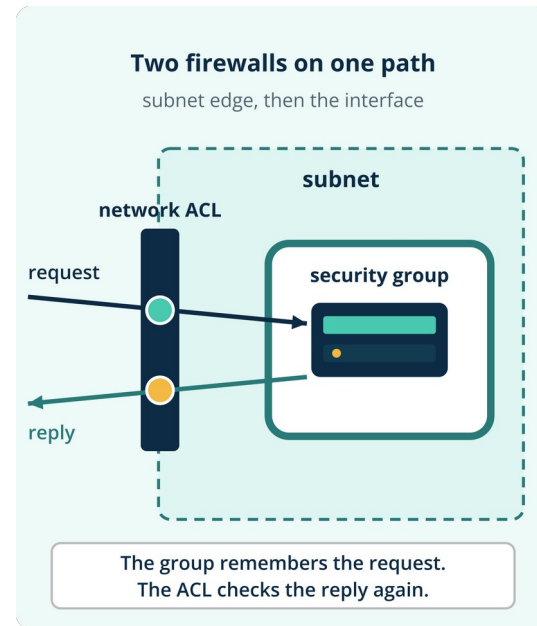
The reply needs its own rule

- Your laptop sends from a temporary high port, an ephemeral port
- The server replies from port 22 back to that port
- A network ACL needs an outbound rule for 1024-65535, or the reply dies

COMMON MISTAKE

Network ACLs are stateful.

They are not. Return traffic needs its own rule.



Subnet edge first, then the interface.

Why both exist, and a group as a source

- A security group is precise, and it cannot deny
- A network ACL can deny a range for a whole subnet, and forgets replies
- A rule may name **another security group** as its source
- SSH from `thara-bastion-sg` means: from whatever wears that group

YOU ALREADY KNOW THIS

A stateful firewall versus a router ACL.

COMMON MISTAKE

Security groups can deny.

They cannot. The absence of an allow is the deny.

CONCEPT 3



Seeing the traffic

How would we know? It begins with flow logs.

20 min

Flow Logs: the cloud's NetFlow

- A flow log records who talked to whom, not what was said
- Fields: interface, addresses, ports, protocol, packets, bytes, time, action
- **ACCEPT** or **REJECT**: the verdict of the two firewalls
- A drop is silent for the sender and on record for you

YOU ALREADY KNOW THIS

NetFlow export to a collector.

T

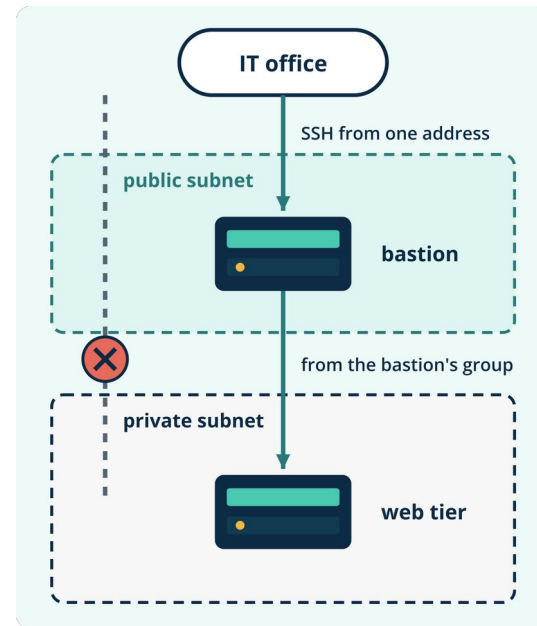
THARA HOSPITALS

The Data Protection Officer's "how would we know?" begins here.

Where the records go, and VPC DNS

- Delivered to **CloudWatch Logs**: a log group, one stream for each interface
- This is your first use of CloudWatch. Day 7 returns for metrics and alarms
- Every VPC has a DNS resolver at its base address plus two
- For `thara-vpc` that is 10.0.0.2. Instances use it without being told

Each interface records its own verdict.



One door in. The log shows who knocked.

Demonstration: The wizard, then what it hid



1. Create a VPC with **VPC and more**. Count the six kinds of thing it made
2. Delete it
3. Build the same by hand, one piece at a time, naming what each needs
4. Two route tables, one with the gateway route: which subnet is public?

Watch the order: this afternoon you build it yourself.

Predict the packet path

40 min

1. Review the paper subnetting exercise and agree the four Thara subnets
2. Trace a patient's browser request to `thara-web-1` and its reply: every hop, table and rule
3. Trace SSH from a random address to the bastion: which firewall stops it?
4. Trace a reply through a network ACL with no ephemeral ports: where does it die?



Common mistakes



COMMON MISTAKE

A subnet named public is public.

Only a route to the gateway, plus a public address, makes it so.

COMMON MISTAKE

Security groups can deny.

They cannot. The absence of an allow is the deny.

COMMON MISTAKE

Network ACLs are stateful.

They are not. Return traffic needs its own rule.

Before the next session



READ

Amazon VPC User Guide

The sections "Security groups" and "Network ACLs".

SELF-CHECK

CLF-C02 bank

Domain 3 networking set A, 15 items.

PRACTICE

PQ3

A VPC design for a two-tier requirement, drawn and justified.

Evidence Pack 3 follows this afternoon's lab.

Questions & Discussion



Next: this afternoon you build components 4, 5 and 6 yourself.



Disclaimer & Copyright



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While I strive to keep the information accurate and up-to-date, I make no representations or warranties of any kind, express or implied, about the completeness, accuracy, reliability, suitability, or availability of the content within this presentation.

Cloud services, prices and free-tier terms change. Figures in this presentation were correct when prepared; check the provider's current documentation before relying on them.

This presentation may include references or links to third-party websites or content. I do not endorse the views expressed or the information provided on such external sites, and I am not responsible for their content.

Thara Hospitals (Pvt) Ltd is a fictional organisation created for teaching. AWS and Amazon Web Services are trademarks of Amazon.com, Inc. or its affiliates; this material is not affiliated with or endorsed by AWS.



© 2026 Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content licensed under CC BY-NC-SA 4.0. Images and artworks used for explanation may contain third-party material used under fair dealing for education.

Revision b8e098a